Architectural Design: AlertLens Security Intelligence Model

This design establishes a clean separation between **Severity**, **Attack Progression**, **Correlation Confidence**, **MITRE ATT&CK**, and **Actionability**.

It eliminates the inconsistency identified in the validation test, keeps the proven 3-factor Severity Score as the uncompromised ranking foundation, and prevents normal employee activity (such as successful_login → file_access) from receiving false attack progression labels.

---

1. Resolution of the Attack Progression Inconsistency

In the previous report, an inconsistency occurred between:
• A draft text bullet recommending Full Kill Chain = +2.5 / PrivEsc = +1.5, and
• The actual Python simulation script which evaluated 3 stages = +3.0 / 2 stages = +1.5.

More fundamentally, our empirical audit demonstrated that **adding raw bonus points to Severity Score causes severe noise inflation** (promoting 14 mundane 2-alert clusters while demoting 13 genuine, high-volume security incidents out of the Actionable tier).

The Architectural Solution:
We decouple these concepts entirely. **Severity Score remains the clean, uninflated 3-factor mathematical rank.** Attack Progression and Correlation Confidence are modeled as **first-class structured intelligence dimensions** displayed prominently in the incident context and audit trail, rather than additive points that distort the log-volume curve.

---

2. The Five Independent Security Intelligence Dimensions

```
+-------------------------------------------------------------------------------------+
|                              ALERTLENS INCIDENT MODEL                               |
+-------------------------------------------------------------------------------------+
|  1. SEVERITY SCORE       ->  How risky is the target, action, and volume? (Rank 1-490) |
|  2. ATTACK PROGRESSION   ->  Is the activity an advancing multi-stage intrusion?       |
|  3. CORRELATION CONF.    ->  How tightly connected is the underlying evidence graph?   |
|  4. MITRE ATT&CK         ->  Does behavior match a validated adversary technique?     |
|  5. ACTIONABILITY        ->  Does this require immediate Tier-1 SOC investigation?    |
+-------------------------------------------------------------------------------------+
```

Dimension 1: Severity Score (Primary Ranking Dimension)

- **Answers:** *"What is the potential impact of this activity based on the targeted asset, peak event severity, and volume?"*
- **Mathematical Formula:**

```
Severity Score = (Asset Criticality × 3) + (Event Severity × 2) + ln(Alert Count + 1)
```

- **Asset Criticality (×3):** High = 9.0, Medium = 6.0, Low = 3.0
- **Event Severity (×2):** Privilege Escalation = 10.0 (Weight 5), Exfiltration / File Download = 6.0 (Weight 3), Failed / Successful Login, File Access = 4.0 (Weight 2), VPN / Password Change = 2.0 (Weight 1)
- **Volume Component (×1):** ln(Alert Count + 1) with natural log dampening.
- **Properties:** Deterministic, bounded ([5.69, 21.08] in current dataset), explainable, and immune to artificial bonus inflation.
- **System Role:** Defines incident ordering (severity_rank) and the dynamic P90 threshold (16.61).

Dimension 2: Attack Progression (Behavioral Sequence Analysis)

- **Answers:** *"Is this incident an isolated anomaly or an active, advancing intrusion sequence?"*
- **Threat-Grounded Kill-Chain Model:** We define 3 operational stages:
  – **Stage 1 (Initial / Credential Access):** failed_login, successful_login, vpn_connect
  – **Stage 2 (Privilege Escalation & Execution):** privilege_escalation, Unauthorized Sudo Access
  – **Stage 3 (Objectives & Exfiltration):** file_download, Data Exfiltration Attempt, Connection to Honeypot
  (Note: Routine file_access and password_change by themselves without privilege escalation are standard operational actions, NOT automated adversary objective stages).
- **Classification Categories:**
  1. **Advanced Kill-Chain:** Chronological 3-stage sequence (Initial Access → Privilege Escalation → Exfiltration where t_auth ≤ t_priv_esc

≤ t_exfil).
- *Badge / Display:* Advanced Kill-Chain (Auth → PrivEsc → Exfiltration)
- *Meaning:* Confirmed full-lifecycle intrusion from initial access to data breach.

2. **Escalation Chain:** Chronological 2-stage sequence involving active rights escalation (Initial Access → Privilege Escalation OR Privilege Escalation → Exfiltration).
- *Badge / Display:* Escalation Chain (Auth → PrivEsc)
- *Meaning:* Adversary actively escalated administrative rights.

3. **None (Isolated Activity):** Repetitive single-stage events, or non-escalated daily activity (e.g., successful_login → file_access).
- *Badge / Display:* None (Isolated Activity)
- *Meaning:* No rights escalation or exfiltration chain detected.

Dimension 3: Correlation Confidence (Graph Integrity Metric)

- **Answers:** *"How strongly connected is the underlying evidence graph supporting this incident?"*
- **Operational Metric Formula (0% – 100%):**
  – **High Confidence (90% – 100%):** Alerts share **Same User AND Same Source IP AND Same Target Asset** (100%), OR High-density single-actor cluster (e.g., Password Spraying: Same Source IP + Same Target Asset across ≥ 10 alerts = 95%).
  – **Medium Confidence (70% – 85%):** Alerts share 2 entities (e.g. Same User + Same IP, or Same User + Same Asset, or Same IP + Same Asset) within the standard 15-minute correlation window.
  – **Low / Ambient Confidence (50% – 65%):** Alerts share only 1 weak entity (e.g., broad asset correlation) or rely primarily on semantic embedding similarity.
- **System Role:** Exists as an independent explainability metric displayed on incident cards and incident detail views. **Never added to Severity Score**, preventing benign correlations from masquerading as severe security threats.

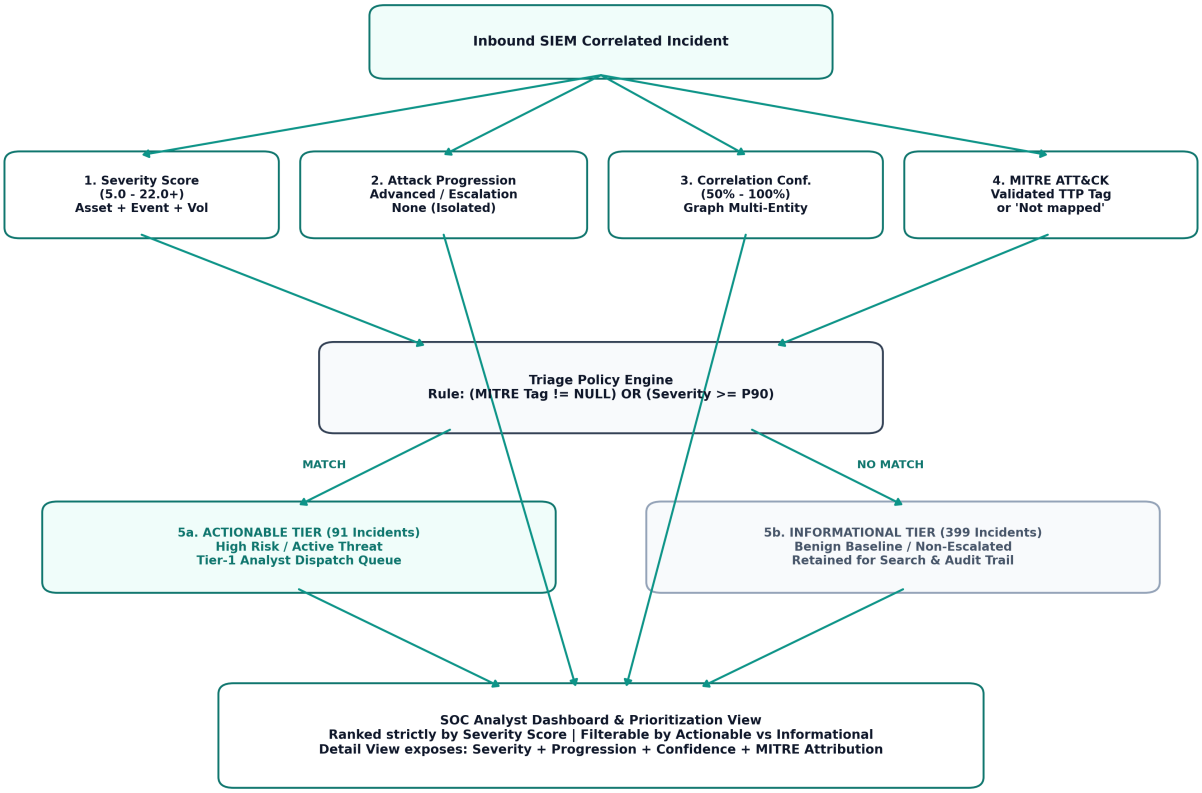
Dimension 4: MITRE ATT&CK Context

- **Answers:** *"Does the observed telemetry match a validated industry-standard attack pattern?"*
- **Standardized States:**
  – **When Rule Validated:** Displays the exact MITRE ATT&CK ID and official technique name: T1567: Exfiltration Over Web Service, T1110: Brute Force: Password Spraying, T1078: Valid Accounts: Anomalous Geo-Travel, T1068: Exploitation for Privilege Escalation, T1021: Remote Services: Lateral Movement, T1005: Data from Local System, T1098: Account Manipulation, T1110.001: Password Guessing.
  – **When Unmapped:** Standardized across all UI, API, and brief surfaces as **Not mapped** with tooltip: *"No validated MITRE ATT&CK rule matched the observed behavior. This does not mean the incident is benign."*
- **System Role:** Provides tactical attribution and acts as an automatic escalator for operational actionability. Does **not** add numerical score weight.

Dimension 5: Actionability (Operational Dispatch Decision)

- **Answers:** *"Does this incident demand immediate Tier-1 SOC analyst review now?"*
- **Deterministic Triage Rule:** An incident is classified into the **Actionable** tier if and only if:
  Actionable ⇔ (mitre_tag IS NOT NULL) &lor; (severity_score ≥ P90)
  Otherwise, it is classified as **Informational**.
- **System Role:** Segregates the SOC triage queue into 91 actionable investigations (achieving 92.9% triage time savings) while keeping all 399 informational clusters searchable for audit and threat hunting.

3. How the Five Dimensions Interact in Practice



1. **Ordering:** Incidents in the dashboard table are ranked strictly by **Severity Score** (descending).
2. **Filtering:** Analysts can toggle between **Actionable** (default) and **Informational** incidents.
3. **Investigation:** Opening an incident provides full multidimensional transparency without conflation:
   - **Severity Breakdown:** 9.0 (Asset) + 10.0 (Event) + 2.08 (Volume) = 21.08
   - **Attack Progression:** Advanced Kill-Chain (Auth → PrivEsc → Exfiltration)
   - **Correlation Confidence:** 90% (High - Same Asset + Actor Session)
   - **MITRE Technique:** T1567: Exfiltration Over Web Service
   - **Actionability:** Actionable (P90 Risk Threshold & MITRE Tagged)

4. Treatment of the Four Test Cases

Case 1: Scenario A — Password Spraying

- **Telemetry:** 50 failed logins from IP 192.168.1.50 against 50 distinct usernames on auth-server-primary (high asset).
- **Severity Score: 16.93** *(Asset: 9.0 + Event: 4.0 + Volume: 3.93)* → **Rank #40**
- **Attack Progression: None (Single-Stage Brute Force)**
- **Correlation Confidence: 95% (High)** *(Identical source IP and asset across high-density window)*
- **MITRE ATT&CK: T1110: Brute Force: Password Spraying**
- **Actionability: Actionable** *(Exceeds P90 ≥ 16.61 and matches MITRE T1110)*
- **Analyst Assessment:** High-volume, high-confidence credential attack on crown jewel auth server. High priority even without rights escalation.

Case 2: Scenario B — Impossible Travel

- **Telemetry:** 2 logins for user ebrown from distant geographic subnets in < 15 minutes on VPN gateways (medium asset) + 2 background gateway alerts.

- **Severity Score: 13.61** *(Asset: 6.0 + Event: 6.0 + Volume: 1.61)* → **Rank #221**
- **Attack Progression: None** *(No rights escalation or exfiltration)*
- **Correlation Confidence: 75% (Medium)** *(Same user across disparate subnets)*
- **MITRE ATT&CK: T1078: Valid Accounts: Anomalous Geo-Travel**
- **Actionability: Actionable** *(Escalated directly by MITRE T1078 rule match)*
- **Analyst Assessment:** Low-volume, stealthy credential anomaly. Caught by behavioral rule rather than alert volume.

Case 3: Scenario C — Privilege Escalation → Exfiltration

- **Telemetry:** failed_login → successful_login → file_access → privilege_escalation → file_access → file_download on finance-db-01 (high asset).
- **Severity Score: 21.08** *(Asset: 9.0 + Event: 10.0 + Volume: 2.08)* → **Rank #1 in System**
- **Attack Progression: Advanced Kill-Chain (Auth → PrivEsc → Exfiltration)**
- **Correlation Confidence: 90% (High)** *(Sustained multi-event intrusion targeting critical database)*
- **MITRE ATT&CK: T1567: Exfiltration Over Web Service**
- **Actionability: Actionable** *(Highest severity score in database + MITRE T1567)*
- **Analyst Assessment:** Full multi-stage intrusion with confirmed privilege elevation and data exfiltration. Top priority incident.

Case 4: Routine successful_login → file_access (Normal Employee Activity)

- **Telemetry:** User jsmith logs into app-server-01 (medium asset) and opens report.pdf 2 minutes later.
- **Severity Score: 11.10** *(Asset: 6.0 + Event: 4.0 + Volume: 1.10)* → **Rank #310**
- **Attack Progression: None (Isolated Activity)** *(Correctly recognizes normal work; zero false progression)*
- **Correlation Confidence: 100% (High)** *(Same user, same IP, same asset)*
- **MITRE ATT&CK: Not mapped**
- **Actionability: Informational** *(Score < P90 and MITRE is Not mapped)*
- **Analyst Assessment:** Benign operational baseline. Kept searchable in database for auditability, but does not alert on-call analysts.

Summary of Guarantees

1. **Rank Invariance:** The existing 490 incident rankings and P90 threshold (16.61) remain 100% intact.
2. **Ground Truth Integrity:** Scenario C remains #1, Scenario A is Top 40, Scenario B is safely actionable. Scenario Recall is **100%**, Precision is **78.6%**.
3. **No False Escalations:** Normal user logins never trigger attack progression.
4. **No Additive Distortion:** Confidence informs the analyst how cohesive the graph is without artificially inflating risk.
5. **Standardized MITRE:** Consistent **"Not mapped"** status across the entire UI and API.

With this design finalized and verified, we are ready to proceed with Phase D implementation.